Cyberbiosecurity ÇORUM 2026

DAY 1 · MONDAY 2 NOVEMBER 2026 · 13:30–14:30

NIST Cybersecurity Framework 2.0

Core Functions and Profiles for the research laboratory



Prof. Dr. Ahmet Altun
Sivas Cumhuriyet University · Faculty of Medicine
Cyberbiosecurity Training Workshop · Hitit University, Çorum

NIST CYBERSECURITY FRAMEWORK 2.0

CORE FUNCTIONS & PROFILES

A common language for securing the biolab

PROF. DR. AHMET ALTUN

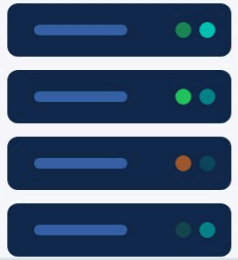
GENE SPAFFORD · PURDUE UNIVERSITY

“The only truly secure system is one that is powered off, cast in a block of concrete and sealed in a lead-lined room with armed guards.”

Our laboratories are powered on.

FEBRUARY 2021 · UNIVERSITY OF OXFORD · STRUCTURAL BIOLOGY

Intruders reached the controls of equipment that prepares biochemical samples



EXPOSED

Pumps and pressure controls

Screenshots shared with Forbes showed live access to instrument interfaces.

CONTEXT

A lab doing COVID-19 research

Timestamps suggested access as recently as 14 February.

RESPONSE

Contained and reported

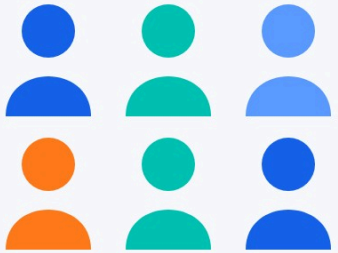
The university notified the NCSC; it said no clinical research or patient data were affected.

THE LESSON Instrument controllers are IT assets. Nobody had them on an inventory, so nobody was protecting them.

ESET WeLiveSecurity, 26 Feb 2021, reporting Forbes and Hold Security

WHY A FRAMEWORK

One vocabulary for the biosafety officer, the IT team and the rector



01 · OUTCOMES

What to achieve, not how

The Core lists outcomes. Your lab chooses the controls that reach them.

02 · ANY ORGANIZATION

Not only critical infrastructure

Version 2.0 is written for organizations of every size, a core facility included.

03 · VOLUNTARY

A map, not a regulation

It sits beside Law 7545 and KVKK and helps organise how you meet them.

A DECADE OF THE FRAMEWORK

From critical infrastructure to every organization

2014

`v1.0 · 12 Feb`

Born from U.S. Executive Order 13636, aimed at **critical infrastructure**.

2018

`v1.1 · 16 Apr`

Adds supply-chain risk, identity and self-assessment. **Five functions.**

2024

`v2.0 · 26 Feb`

Written for **all organizations**. A sixth function, **GOVERN**, at the centre.

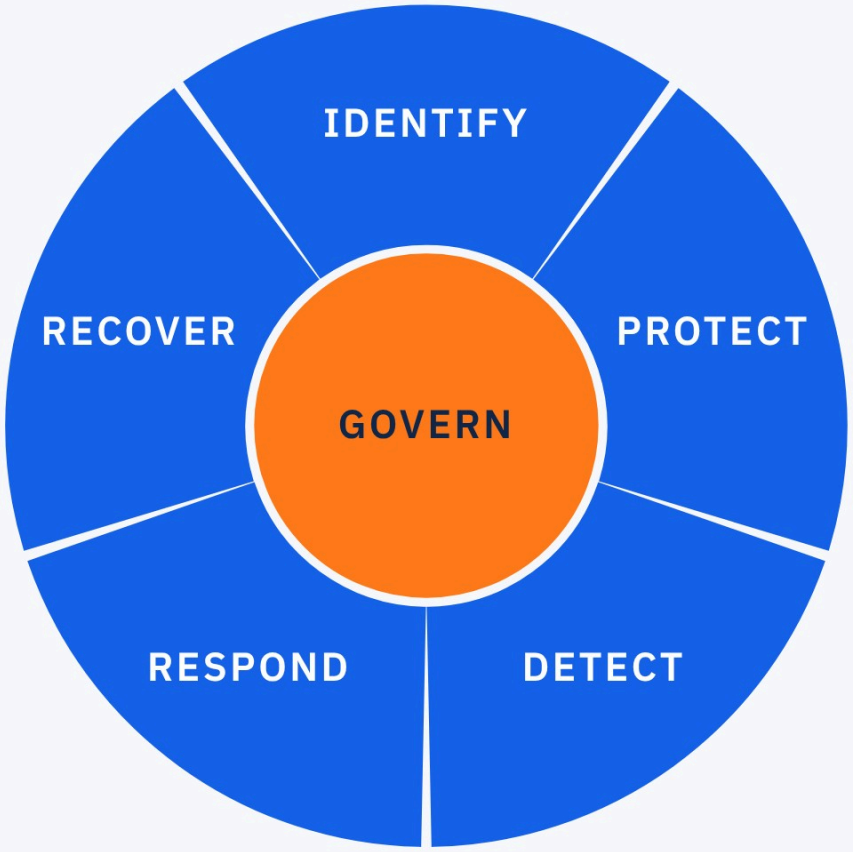


Five functions became six.

The empty centre of the old wheel now holds the function that steers the other five.

NIST CSF 2.0 · THE CORE

Six functions, working at the same time



GV — Govern
Strategy, expectations and policy are established, communicated and monitored.

ID — Identify
The organization’s current cybersecurity risks are understood.

PR — Protect
Safeguards to manage cybersecurity risks are used.

DE — Detect
Possible attacks and compromises are found and analyzed.

RS — Respond
Actions regarding a detected incident are taken.

RC — Recover
Affected assets and operations are restored.

THE CORE · GV

Govern



Cybersecurity risk management strategy, expectations and policy are established, communicated and monitored.

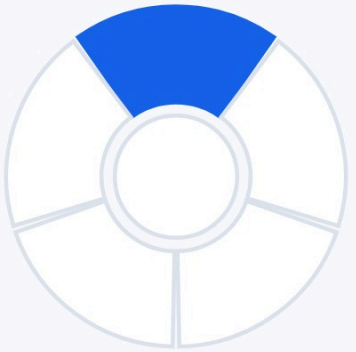
- **GV.OC** Organizational Context
- **GV.RM** Risk Management Strategy
- **GV.RR** Roles, Responsibilities & Authorities
- **GV.PO** Policy
- **GV.OV** Oversight
- **GV.SC** Supply Chain Risk Management

IN THE LAB

Who owns the risk of a networked −80 °C freezer: the lab head, the biosafety officer, or IT? GOVERN makes someone answer, in writing.

FUNCTION · ID

Identify



The organization’s current cybersecurity risks are understood.

ID.AM	Asset Management
ID.RA	Risk Assessment
ID.IM	Improvement

3 categories · ID.AM, ID.RA, ID.IM

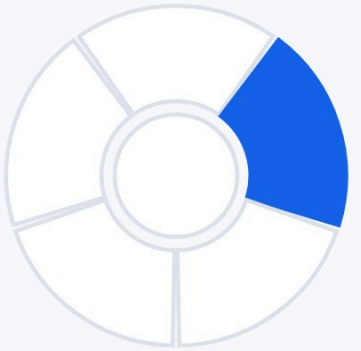


IN THE LAB

The sequencer PC on an unsupported OS, the Wi-Fi freezer alarm, the shared analysis server: if it is not on the inventory, it is not protected.

FUNCTION · PR

Protect



Safeguards to manage the organization’s cybersecurity risks are used.

- **PR.AA** Identity, Authentication & Access
- **PR.AT** Awareness & Training
- **PR.DS** Data Security
- **PR.PS** Platform Security
- **PR.IR** Infrastructure Resilience

IN THE LAB

Named accounts on instrument PCs, MFA on every remote session, a separate network for lab equipment, and staff who recognise a fake “vendor engineer” call.

FUNCTION · DE

Detect

Possible cybersecurity attacks and compromises are found and analyzed.



DE.CM **Continuous Monitoring**

DE.AE **Adverse Event Analysis**

2 categories · DE.CM, DE.AE



IN THE LAB

In the 2021 Irish health service attack, antivirus detected the intruder on 31 March but was in monitor mode. Detection without analysis is only a log entry.

FUNCTION · RS

Respond

Actions regarding a detected cybersecurity incident are taken.



RS.MA Incident Management

RS.AN Incident Analysis

RS.CO Reporting & Communication

RS.MI Incident Mitigation

IN THE LAB

Contain without causing a biosafety incident: isolate the instrument network, not the freezer's power. The biosafety officer belongs at the response table.

FUNCTION · RC

Recover

Assets and operations affected by a cybersecurity incident are restored.



RC.RP	Recovery Plan Execution
RC.CO	Recovery Communication

2 categories · RC.RP, RC.CO



IN THE LAB

After the June 2024 ransomware attack on Synnovis, a London pathology provider, 10,146 outpatient appointments and 1,705 elective procedures were postponed.

HOW THE CORE IS BUILT

6 Functions

22 Categories

106 Subcategories

Each subcategory links to **Implementation Examples** and **Informative References**, published online so they can change without a new framework.

ONE THREAD THROUGH THE CORE

From a function to a task on the bench



IDENTIFY — ID.AM · Asset Management — ID.AM-01

SUBCATEGORY

“Inventories of hardware managed by the organization are maintained.”

NIST IMPLEMENTATION EXAMPLE

All types of hardware

Maintain inventories for all types of hardware, including IT, IoT, OT, and mobile devices.

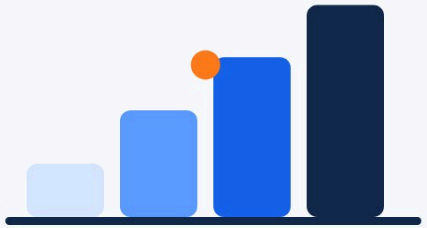
IN A BIOTECH LAB THIS MEANS

Bench-level inventory

Instrument control PCs and their OS versions · freezer, incubator and cabinet controllers · data loggers, tablets, USB sticks

TIERS

How rigorous are our practices?



Tiers are not a score to maximise. Choose the tier your risk justifies; a teaching lab and a BSL-3 core facility need different targets.

1

Partial

Managed ad hoc; limited awareness across the organization.

2

Risk Informed

Approved by management, not yet organization-wide policy.

3

Repeatable

Formally approved, expressed as policy, regularly updated.

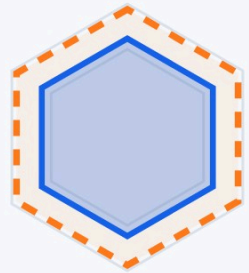
4

Adaptive

Adapts from lessons learned and predictive indicators.

PROFILES

The CSF applied to your own laboratory



WHERE WE ARE

Current Profile

WHERE WE MUST BE

Target Profile

THE GAP

Outcome by outcome

The difference between the two profiles.

THE ACTION PLAN

Owners, budget, dates

Prioritised work that closes the gap.

THE CYCLE

Implement, then update

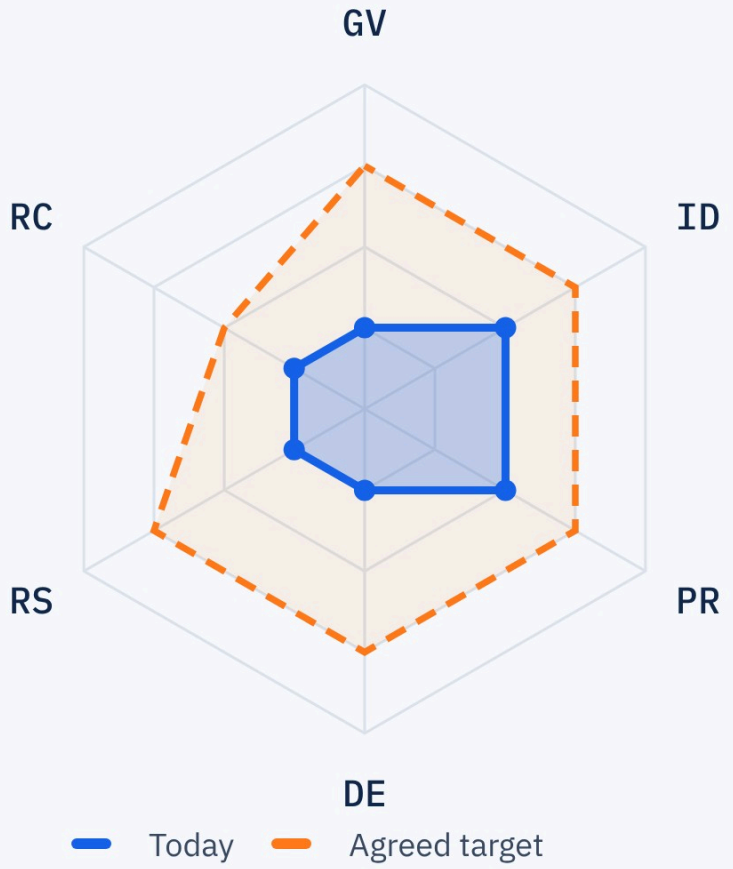
Re-rate the Current Profile. Repeat.

WORKED EXAMPLE · ILLUSTRATIVE

A core facility's profile and its gaps

Illustrative values for a university core facility that serves external industry clients. Tiers 1–4 per function.

- **GV.SC** Client samples and data arrive from outside; vendors log in remotely
- **DE.CM** No central logging from instrument PCs
- **RC.RP** Backups exist; a restore has never been tested



TWO KINDS OF PROFILE

Build your own, or start from a shared one



ORGANIZATIONAL PROFILE

Yours

Current and Target for one organization or facility. NIST publishes a Quick-Start Guide and a fillable template.

COMMUNITY PROFILE

Shared by a sector or a topic

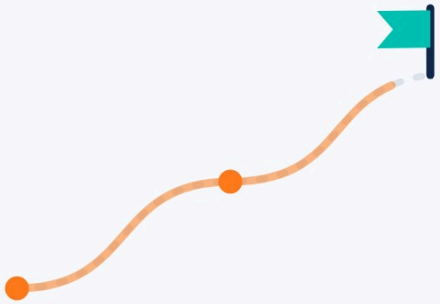
SP 800-61 Rev. 3 (April 2025): incident response organised by CSF 2.0 functions.
Cyber AI Profile, NIST IR 8596 (preliminary draft, Dec 2025): Secure, Defend, Thwart.

TOMORROW

The Cyber AI Profile is where tomorrow morning starts: **09:15 · NIST AI Risk Management Framework**.

NIST QUICK-START GUIDE · ORGANIZATIONAL PROFILES

Five steps from framework to action plan



1

Scope

Which unit, systems and risks?

2

Gather

Policies, inventories, legal duties

3

Create

Rate Current and Target

4

Analyze

Gaps → prioritised action plan

5

Implement

Act, then update the profile

TOMORROW 14:30 Tomorrow’s exercise compresses steps 1–4 into 45 minutes for a fictional biotech lab.

IN TÜRKIYE

Voluntary framework, binding duties



LAW NO. 7545 · RG 19 MARCH 2025

Cybersecurity Law

Covered entities report detected vulnerabilities and incidents to the Cyber Security Presidency **without delay**.

`maps to RS.CO · GV.OC`

LAW NO. 6698 · KVKK

Personal data protection

Personal data breaches go to the KVKK Board within **72 hours** (Board Decision 2019/10).

`maps to RS.CO · PR.DS`

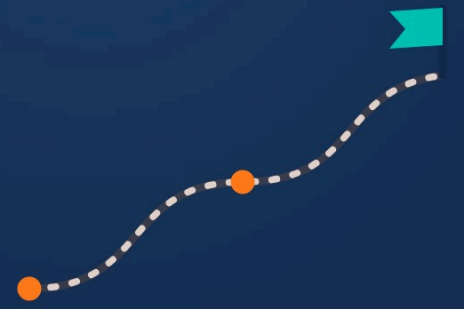
IN PRACTICE

The CSF does not replace these duties. It is where you show how you meet them. Confirm with your institution’s legal office which apply.

THREE THINGS TO KEEP

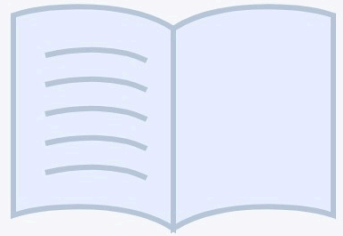
Govern first.
Know what you run.
Profile, then act.

Today 15:30 · Laboratory asset mapping (Prof. Dr. Gökçe Merey) · Tomorrow 14:30 · Build your lab’s profile



SOURCES

References and further reading



1. National Institute of Standards and Technology. *The NIST Cybersecurity Framework (CSF) 2.0*. NIST CSWP 29; 2024. doi:10.6028/NIST.CSWP.29
2. Nelson A, Rekhi S, Souppaya M, Scarfone K. *Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile*. NIST SP 800-61r3; 2025. doi:10.6028/NIST.SP.800-61r3
3. NIST. *Cybersecurity Framework Profile for Artificial Intelligence*. NIST IR 8596, initial preliminary draft; 16 Dec 2025.
4. Murch RS, So WK, Buchholz WG, Raman S, Peccoud J. Cyberbiosecurity: an emerging new discipline to help safeguard the bioeconomy. *Front Bioeng Biotechnol*. 2018;6:39. doi:10.3389/fbioe.2018.00039
5. Peccoud J, Gallegos JE, Murch R, Buchholz WG, Raman S. Cyberbiosecurity: from naive trust to risk awareness. *Trends Biotechnol*. 2018;36(1):4–7. doi:10.1016/j.tibtech.2017.10.012
6. NHS England (London). Update on cyber incident clinical impact in south east London; 19 Sep 2024.
7. ESET WeLiveSecurity. Oxford University lab studying COVID-19 hit by cyberattack; 26 Feb 2021.
8. 7545 sayılı Siber Güvenlik Kanunu, Resmî Gazete 32846, 19 Mar 2025 · 6698 sayılı KVKK; KVK Kurulu Kararı 2019/10.

QUESTIONS & DISCUSSION

Thank you.

Questions on the framework, the functions or profiles



Prof. Dr. Ahmet Altun
Sivas Cumhuriyet University · Faculty of Medicine
aaltun@cumhuriyet.edu.tr · ORCID 0000-0003-2056-8683